PRD — Web Portofolio + CMS Pribadi

Versi 1.0 · 29 Oktober 2026 · Dokumen acuan utama untuk AI Coding Agent (Antigravity): scaffolding & generasi kode modular, terstruktur, dan aman.

1. Executive Summary & Objectives

1.1 Ringkasan

Web Portofolio + CMS Pribadi adalah satu aplikasi dengan dua sisi: **situs publik** (hero, showcase proyek, tech stack, pengalaman, sertifikat, blog, form kontak) dan **dashboard admin** `/admin` (CRUD semua konten dan inbox pesan). Seluruh konten dikelola lewat CMS sehingga pemilik tidak perlu mengubah kode untuk update portofolio.

1.2 Tujuan

1. **Local-first**: seluruh sistem berjalan penuh di localhost tanpa dependensi cloud.
2. **Modular**: setiap domain (projects, skills, certificates, dst.) berdiri sendiri: handler → service → repository.
3. **Efisien resource**: backend Go single binary, memori rendah, query terindeks, gambar dioptimalkan.
4. **Security-first**: auth aman, validasi ketat, sanitasi XSS, rate limit, upload aman.
5. **Siap Appwrite**: data layer dan storage dibungkus *interface* sehingga migrasi ke Appwrite Cloud hanya mengganti implementasi, bukan logika bisnis.

1.3 Non-Goals (v1)

Multi-user/multi-tenant, komentar publik, pembayaran, i18n penuh, light mode.

1.4 Keputusan Teknis Final (jangan diubah Antigravity tanpa persetujuan)

Area	Keputusan
Backend	Go 1.23+, **Fiber v2**, `pgx/v5`, `golang-migrate`, `goldmark` + `bluemonday`, `go-playground/validator`, `argon2id`
Frontend	**React 18 + Vite + TypeScript**, React Router, TanStack Query, Tailwind CSS, **shadcn/ui**, `react-hook-form` + `zod`, `framer-motion` (secukupnya)

Area	Keputusan
Database	PostgreSQL 16 lokal (fallback SQLite hanya untuk test cepat; DDL utama = PostgreSQL)
Storage	Filesystem lokal `./storage/uploads` lewat interface `StorageProvider`
Auth	JWT di **httpOnly Secure SameSite=Strict cookie** + CSRF double-submit untuk request admin yang mengubah data
Alasan Vite SPA	Sederhana, mudah di-host statis di Appwrite Sites; SEO dasar via meta tag per halaman (`react-helmet-async`) dan opsi prerender di fase akhir

2. System Architecture & Local Development Setup

2.1 Rantai Data Lokal

```
Browser (Vite dev :5173) --HTTP /api--> Go Fiber API (:8080)
                                          |-- pgx --> PostgreSQL lokal
(:5432)
                                          |-- StorageProvider(local) -->
./storage/uploads
```

Di dev, Vite memakai proxy `/api` dan `/uploads` ke `:8080` agar cookie same-site dan CORS minimal. Di produksi lokal, Go juga bisa menyajikan build frontend (`./web/dist`).

2.2 Struktur Monorepo

```
portfolio/
├─ apps/
│  ├─ api/                    # Go backend
│  │  ├─ cmd/server/main.go
│  │  ├─ internal/
│  │  │  ├─ config/           # load .env, validasi wajib
│  │  │  ├─ database/         # pgxpool, migrasi
│  │  │  ├─ middleware/       # auth, ratelimit, cors, logger, secure
headers, csrf
│  │  │  ├─ domain/           # struct entity + DTO per modul
│  │  │  ├─ repository/       # interface + impl postgres
│  │  │  ├─ service/          # logika bisnis
│  │  │  ├─ handler/          # Fiber handler (tipis)
```

```
|  |  |  ├─ storage/          # StorageProvider: local (sekarang), appwrite
(nanti)
|  |  |  └─ sanitize/         # markdown -> html aman
|  |  ├─ migrations/          # 0001_init.up.sql / .down.sql
|  |  └─ go.mod
|  └─ web/                    # React + Vite
|     └─ src/{components,pages,admin,lib,hooks,styles}
├─ storage/uploads/           # gitignored
├─ .env.example
└─ docker-compose.yml         # opsional: hanya postgres lokal
```

2.3 Konfigurasi `.env` Lokal

```
APP_ENV=development
APP_PORT=8080
APP_BASE_URL=http://localhost:5173
DATABASE_URL=postgres://portfolio:portfolio@localhost:5432/portfolio?
sslmode=disable
JWT_SECRET=ganti-dengan-random-minimal-32-byte
JWT_TTL_HOURS=12
COOKIE_SECURE=false          # true di produksi (HTTPS)
CORS_ALLOWED_ORIGINS=http://localhost:5173
STORAGE_DRIVER=local          # local | appwrite
STORAGE_LOCAL_DIR=./storage/uploads
UPLOAD_MAX_BYTES=2097152
RATE_LIMIT_CONTACT_PER_HOUR=5
ADMIN_SEED_EMAIL=admin@local.test
ADMIN_SEED_PASSWORD=ganti-saat-seed
```

Aturan: `.env` masuk `.gitignore`; sediakan `.env.example` tanpa nilai rahasia; `config.Load()` **gagal start** bila `JWT_SECRET` kurang dari 32 karakter atau kosong.

2.4 Instruksi Eksekusi untuk Antigravity (urutan wajib)

1. **Fase 0 — Scaffold**: buat monorepo, `go mod init`, `npm create vite`, install Tailwind + shadcn/ui, set tema dark (lihat Bagian 5).
2. **Fase 1 — Database**: tulis migrasi dari DDL Bagian 3; buat perintah `make migrate-up` dan seeder admin (`cmd/seed`).
3. **Fase 2 — Backend inti**: config, pool DB, middleware, auth (login/logout/me), health check `/api/health`.
4. **Fase 3 — Modul konten**: profile, categories, skills, projects(+project_skills), experiences, certificates, posts — satu modul selesai (repo+service+handler+test) sebelum modul berikutnya.

5. **Fase 4 — Upload & Messages**: StorageProvider lokal, endpoint upload, endpoint kontak + rate limit.
6. **Fase 5 — Frontend publik** lalu **Fase 6 — Admin CMS**.
7. **Fase 7 — Hardening**: jalankan Checklist Keamanan (Bagian 6), `go vet`, `staticcheck`, `govulncheck`, `npm audit`.

Aturan generasi kode: handler tidak boleh berisi SQL; semua SQL memakai parameter (`$1, $2`); tidak ada string concat query; error internal tidak dibocorkan ke client; setiap modul punya unit test minimal untuk service.

3. Database Schema & Data Dictionary

3.1 DDL Lengkap (PostgreSQL 16)

```
CREATE EXTENSION IF NOT EXISTS pgcrypto;
CREATE EXTENSION IF NOT EXISTS citext;

CREATE OR REPLACE FUNCTION set_updated_at() RETURNS trigger AS $$
BEGIN NEW.updated_at = now(); RETURN NEW; END; $$ LANGUAGE plpgsql;

-- 1. users (admin CMS)
CREATE TABLE users (
  id            UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  email         CITEXT NOT NULL UNIQUE,
  password_hash TEXT NOT NULL,
  name          VARCHAR(100) NOT NULL,
  role          VARCHAR(20) NOT NULL DEFAULT 'admin' CHECK (role IN
('admin')),
  failed_logins SMALLINT NOT NULL DEFAULT 0,
  locked_until  TIMESTAMPTZ,
  last_login_at TIMESTAMPTZ,
  created_at    TIMESTAMPTZ NOT NULL DEFAULT now(),
  updated_at    TIMESTAMPTZ NOT NULL DEFAULT now()
);

-- 2. profile (satu baris per user)
CREATE TABLE profile (
  id             UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  user_id        UUID NOT NULL UNIQUE REFERENCES users(id) ON DELETE CASCADE,
  full_name      VARCHAR(120) NOT NULL,
  headline       VARCHAR(160) NOT NULL,
  bio_md         TEXT NOT NULL DEFAULT '',
  bio_html       TEXT NOT NULL DEFAULT '',   -- hasil sanitasi
  location       VARCHAR(120),
```

```
  public_email   VARCHAR(160),
  avatar_path    TEXT,
  resume_path    TEXT,
  github_url     TEXT,
  linkedin_url   TEXT,
  social_links   JSONB NOT NULL DEFAULT '[]'::jsonb,  -- [{label,url}]
  open_to_work   BOOLEAN NOT NULL DEFAULT false,
  updated_at     TIMESTAMPTZ NOT NULL DEFAULT now()
);

-- 3. categories (dipakai projects & posts)
CREATE TABLE categories (
  id         UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  name       VARCHAR(80) NOT NULL,
  slug       VARCHAR(100) NOT NULL,
  type       VARCHAR(10) NOT NULL CHECK (type IN ('project','post')),
  sort_order INT NOT NULL DEFAULT 0,
  created_at TIMESTAMPTZ NOT NULL DEFAULT now(),
  UNIQUE (type, slug)
);

-- 4. projects
CREATE TABLE projects (
  id             UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  category_id    UUID REFERENCES categories(id) ON DELETE SET NULL,
  title          VARCHAR(160) NOT NULL,
  slug           VARCHAR(180) NOT NULL UNIQUE,
  summary        VARCHAR(300) NOT NULL,
  description_md TEXT NOT NULL DEFAULT '',
  description_html TEXT NOT NULL DEFAULT '',
  thumbnail_path TEXT,
  repo_url       TEXT,
  demo_url       TEXT,
  status         VARCHAR(20) NOT NULL DEFAULT 'draft' CHECK (status IN
('draft','published','archived')),
  is_featured    BOOLEAN NOT NULL DEFAULT false,
  sort_order     INT NOT NULL DEFAULT 0,
  started_at     DATE,
  ended_at       DATE,
  created_at     TIMESTAMPTZ NOT NULL DEFAULT now(),
  updated_at     TIMESTAMPTZ NOT NULL DEFAULT now()
);
CREATE INDEX idx_projects_status_sort ON projects (status, is_featured DESC,
sort_order, created_at DESC);
CREATE INDEX idx_projects_category ON projects (category_id);
```

```
-- 5. skills
CREATE TABLE skills (
  id          UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  name        VARCHAR(60) NOT NULL UNIQUE,
  slug        VARCHAR(80) NOT NULL UNIQUE,
  group_name  VARCHAR(20) NOT NULL DEFAULT 'tool' CHECK (group_name IN
('language','framework','database','tool','cloud','other')),
  icon_key    VARCHAR(60),                -- kunci ikon (mis. simple-icons
slug)
  brand_color CHAR(7) CHECK (brand_color ~ '^#[0-9A-Fa-f]{6}$'),  -- warna
glow saat hover
  level       SMALLINT CHECK (level BETWEEN 1 AND 5),
  is_visible  BOOLEAN NOT NULL DEFAULT true,
  sort_order  INT NOT NULL DEFAULT 0
);

-- 6. project_skills (many-to-many)
CREATE TABLE project_skills (
  project_id UUID NOT NULL REFERENCES projects(id) ON DELETE CASCADE,
  skill_id   UUID NOT NULL REFERENCES skills(id)   ON DELETE CASCADE,
  PRIMARY KEY (project_id, skill_id)
);
CREATE INDEX idx_project_skills_skill ON project_skills (skill_id);

-- 7. experiences
CREATE TABLE experiences (
  id           UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  type         VARCHAR(20) NOT NULL CHECK (type IN
('work','education','organization','volunteer')),
  organization VARCHAR(160) NOT NULL,
  role         VARCHAR(160) NOT NULL,
  location     VARCHAR(120),
  description_md   TEXT NOT NULL DEFAULT '',
  description_html TEXT NOT NULL DEFAULT '',
  start_date   DATE NOT NULL,
  end_date     DATE,
  is_current   BOOLEAN NOT NULL DEFAULT false,
  is_visible   BOOLEAN NOT NULL DEFAULT true,
  sort_order   INT NOT NULL DEFAULT 0,
  created_at   TIMESTAMPTZ NOT NULL DEFAULT now(),
  updated_at   TIMESTAMPTZ NOT NULL DEFAULT now(),
  CHECK (end_date IS NULL OR end_date >= start_date)
);
CREATE INDEX idx_experiences_order ON experiences (is_visible, start_date
DESC);
```

```
-- 8. certificates
CREATE TABLE certificates (
  id             UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  title          VARCHAR(200) NOT NULL,
  issuer         VARCHAR(160) NOT NULL,
  credential_id  VARCHAR(120),
  credential_url TEXT,
  issued_at      DATE NOT NULL,
  expires_at     DATE,
  file_path      TEXT NOT NULL,            -- gambar atau PDF
  file_mime      VARCHAR(30) NOT NULL CHECK (file_mime IN
('application/pdf','image/png','image/jpeg','image/webp')),
  thumbnail_path TEXT,
  is_visible     BOOLEAN NOT NULL DEFAULT true,
  sort_order     INT NOT NULL DEFAULT 0,
  created_at     TIMESTAMPTZ NOT NULL DEFAULT now(),
  updated_at     TIMESTAMPTZ NOT NULL DEFAULT now()
);
CREATE INDEX idx_certificates_visible ON certificates (is_visible, issued_at
DESC);

-- 9. posts (blog)
CREATE TABLE posts (
  id           UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  author_id    UUID NOT NULL REFERENCES users(id) ON DELETE RESTRICT,
  category_id  UUID REFERENCES categories(id) ON DELETE SET NULL,
  title        VARCHAR(200) NOT NULL,
  slug         VARCHAR(220) NOT NULL UNIQUE,
  excerpt      VARCHAR(320) NOT NULL DEFAULT '',
  content_md   TEXT NOT NULL,
  content_html TEXT NOT NULL,              -- hasil goldmark + bluemonday
  cover_path   TEXT,
  status       VARCHAR(20) NOT NULL DEFAULT 'draft' CHECK (status IN
('draft','published','archived')),
  reading_minutes SMALLINT NOT NULL DEFAULT 1,
  published_at TIMESTAMPTZ,
  created_at   TIMESTAMPTZ NOT NULL DEFAULT now(),
  updated_at   TIMESTAMPTZ NOT NULL DEFAULT now()
);
CREATE INDEX idx_posts_published ON posts (status, published_at DESC);

-- 10. messages (inbox form kontak)
CREATE TABLE messages (
  id         UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  name       VARCHAR(100) NOT NULL,
  email      VARCHAR(160) NOT NULL,
```

```
  subject    VARCHAR(160) NOT NULL DEFAULT '',
  body       TEXT NOT NULL CHECK (char_length(body) BETWEEN 10 AND 5000),
  status     VARCHAR(12) NOT NULL DEFAULT 'unread' CHECK (status IN
('unread','read','archived','spam')),
  ip_hash    CHAR(64),                      -- SHA-256(ip + salt), bukan IP
mentah
  user_agent VARCHAR(255),
  created_at TIMESTAMPTZ NOT NULL DEFAULT now(),
  read_at    TIMESTAMPTZ
);
CREATE INDEX idx_messages_status_created ON messages (status, created_at
DESC);

-- trigger updated_at
DO $$ DECLARE t TEXT; BEGIN
  FOREACH t IN ARRAY
ARRAY['users','profile','projects','experiences','certificates','posts'] LOOP
    EXECUTE format('CREATE TRIGGER trg_%s_updated BEFORE UPDATE ON %I FOR
EACH ROW EXECUTE FUNCTION set_updated_at()', t, t);
  END LOOP;
END $$;
```

3.2 Relasi Ringkas

- `users 1–1 profile`, `users 1–N posts`.
- `categories 1–N projects` dan `categories 1–N posts` (dibedakan kolom `type`; validasi di service agar kategori project tidak dipakai post).
- `projects N–M skills` via `project_skills`.
- `experiences`, `certificates`, `messages` berdiri sendiri.

3.3 Data Dictionary — Aturan Penting

- Semua PK `UUID`; path file disimpan **relatif** (mis. `projects/3f2a....webp`), bukan path absolut, supaya portabel ke Appwrite.
- Kolom `*_md` adalah sumber edit; kolom `*_html` adalah hasil render+sanitasi dan **satu-satunya** yang boleh direnderi frontend.
- `messages.ip_hash` adalah hash berasam; IP mentah tidak disimpan.
- `status = published` wajib untuk tampil di API publik; draft/archived hanya via API admin.

4. Backend & API Specification (Go)

4.1 Konvensi

- Base path `/api/v1`. JSON UTF-8. Waktu ISO-8601 UTC.
- Envelope sukses: `{ "data": ..., "meta": { "page":1, "per_page":12, "total":40 } }`.
- Envelope error: `{ "error": { "code":"VALIDATION_ERROR", "message":"...", "fields":{ "email":"format tidak valid" } } }`.
- Kode status: 200/201/204, 400, 401, 403, 404, 409, 413, 415, 422, 429, 500. Pesan 500 generik; detail hanya di log.

4.2 Endpoint Publik

Method	Path	Fungsi
GET	`/health`	Cek hidup
GET	`/profile`	Profil publik
GET	`/projects?category=&skill=&featured=&page=`	Daftar proyek published
GET	`/projects/:slug`	Detail proyek + skills
GET	`/skills`	Skill visible (untuk Tech Stack & filter)
GET	`/categories?type=`	Kategori
GET	`/experiences`	Pengalaman visible
GET	`/certificates`	Sertifikat visible
GET	`/posts?category=&page=`	Daftar post published
GET	`/posts/:slug`	Detail post
POST	`/contact`	Kirim pesan (rate limited, honeypot)
GET	`/uploads/*`	Serve file (lokal), header `X-Content-Type-Options: nosniff`

4.3 Endpoint Admin (wajib auth; mutasi wajib header `X-CSRF-Token`)

Method	Path	Fungsi
POST	`/auth/login`	Login, set cookie (rate limit ketat)
POST	`/auth/logout`	Hapus cookie
GET	`/auth/me`	User aktif
GET	`/admin/stats`	Jumlah proyek, skill, sertifikat, post, pesan unread
PUT	`/admin/profile`	Update profil
CRUD	`/admin/projects` (+ `PUT /admin/projects/:id/skills`)	Proyek
CRUD	`/admin/skills`	Skill
CRUD	`/admin/categories`	Kategori
CRUD	`/admin/experiences`	Pengalaman
CRUD	`/admin/certificates`	Sertifikat
CRUD	`/admin/posts`	Blog
GET/PATCH/DELETE	`/admin/messages`, `/admin/messages/:id`	Inbox, ubah status, hapus
POST	`/admin/uploads?kind=thumbnail|certificate|resume|avatar|cover`	Upload multipart, kembalikan `path` relatif
DELETE	`/admin/uploads?path=`	Hapus file (validasi path)

4.4 DTO / Struct Go (contoh pola; modul lain mengikuti pola sama)

```
// domain/project.go
type ProjectCreateRequest struct {
    Title         string   `json:"title" validate:"required,min=3,max=160"`
    Slug          string   `json:"slug" validate:"omitempty,slug,max=180"` //
kosong -> auto dari title
    Summary       string   `json:"summary" validate:"required,max=300"`
    DescriptionMD string   `json:"description_md" validate:"max=50000"`
    CategoryID    *string  `json:"category_id" validate:"omitempty,uuid"`
    ThumbnailPath *string  `json:"thumbnail_path"
validate:"omitempty,max=255"`
    RepoURL       *string  `json:"repo_url"
validate:"omitempty,url,startswith=https://"`
    DemoURL       *string  `json:"demo_url"
validate:"omitempty,url,startswith=https://"`
    Status        string   `json:"status" validate:"required,oneof=draft
published archived"`
    IsFeatured    bool     `json:"is_featured"`
    SkillIDs      []string `json:"skill_ids" validate:"dive,uuid"`
}

type ProjectResponse struct {
    ID              string          `json:"id"`
    Title           string          `json:"title"`
    Slug            string          `json:"slug"`
    Summary         string          `json:"summary"`
    DescriptionHTML string          `json:"description_html"`
    ThumbnailURL    *string         `json:"thumbnail_url"`
    RepoURL         *string         `json:"repo_url"`
    DemoURL         *string         `json:"demo_url"`
    Category        *CategoryBrief  `json:"category"`
    Skills          []SkillBrief    `json:"skills"`
    IsFeatured      bool            `json:"is_featured"`
    CreatedAt       time.Time       `json:"created_at"`
}

// domain/auth.go
type LoginRequest struct {
    Email    string `json:"email" validate:"required,email,max=160"`
    Password string `json:"password" validate:"required,min=8,max=128"`
}

// domain/message.go
type ContactRequest struct {
    Name    string `json:"name" validate:"required,min=2,max=100"`
```

```
    Email   string `json:"email" validate:"required,email,max=160"`
    Subject string `json:"subject" validate:"max=160"`
    Body    string `json:"body" validate:"required,min=10,max=5000"`
    Website string `json:"website" validate:"max=0"` // honeypot: harus
kosong
}
```

Catatan: URL eksternal hanya `https://`; `javascript:` / `data:` ditolak. Semua string di-`TrimSpace` dan dinormalisasi Unicode (NFC) di layer service.

4.5 Middleware (urutan pemasangan di Fiber)

1. **Recover** — tangkap panic, balas 500 generik.
2. **RequestID + Logger** — log terstruktur (`slog` / `zerolog`): method, path, status, durasi, request_id. **Jangan** log body, password, token, atau cookie.
3. **Secure Headers** — `Content-Security-Policy: default-src 'self'; img-src 'self' data:; style-src 'self' 'unsafe-inline'; script-src 'self'; frame-ancestors 'none'; object-src 'none'`, `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: strict-origin-when-cross-origin`, `Permissions-Policy: camera=(), microphone=(), geolocation=()`, `Strict-Transport-Security` (hanya saat `COOKIE_SECURE=true`). Untuk PDF viewer, sediakan pengecualian `frame-src 'self'` pada route `/uploads` saja.
4. **CORS** — origin dari `CORS_ALLOWED_ORIGINS` (tanpa wildcard bila `AllowCredentials=true`), method terbatas, header `Content-Type, X-CSRF-Token`.
5. **Body Limit** — default 1 MB; endpoint upload 2 MB + overhead multipart.
6. **Rate Limiter** — global 100 req/menit/IP; `/auth/login` 5 per 15 menit per IP+email; `/contact` sesuai `RATE_LIMIT_CONTACT_PER_HOUR` per IP. Implementasi in-memory (sliding window) dengan interface agar bisa diganti.
7. **Auth** (grup `/admin`) — baca JWT dari cookie, verifikasi HS256 (tolak `alg` lain), cek `exp`, muat user, set `c.Locals("user")`.
8. **CSRF** — double-submit token untuk method `POST/PUT/PATCH/DELETE` pada `/admin/*`; token dikirim lewat cookie non-httpOnly + header `X-CSRF-Token`, dibandingkan constant-time.

4.6 Aturan Auth

- Password di-hash **argon2id** (m=64MB, t=3, p=2) atau bcrypt cost ≥ 12; pesan login gagal selalu generik.
- Akun terkunci 15 menit setelah 5 gagal login (`failed_logins`, `locked_until`).
- Cookie: `HttpOnly; Secure (prod); SameSite=Strict; Path=/; Max-Age=JWT_TTL`.

4.7 Aturan Upload

- Whitelist ekstensi **dan** deteksi MIME dari magic bytes (`http.DetectContentType`), keduanya harus cocok: `image/webp` , `image/jpeg` , `image/png` , `application/pdf` .
- Maks 2 MB. Nama file asli **dibuang**; simpan sebagai `{kind}/{uuid}.{ext}` .
- Path hasil `filepath.Join` harus tetap berawalan `STORAGE_LOCAL_DIR` (cek `filepath.Rel`); tolak `..` , null byte, dan symlink.
- Gambar di-re-encode (strip EXIF) bila memungkinkan; PDF disajikan dengan `Content-Disposition: inline` + `nosniff` .

4.8 Interface Abstraksi (kunci migrasi Appwrite)

```
type StorageProvider interface {
    Save(ctx context.Context, kind string, r io.Reader, mime string) (path
string, err error)
    Delete(ctx context.Context, path string) error
    PublicURL(path string) string
}
type ProjectRepository interface {
    List(ctx context.Context, f ProjectFilter) ([]Project, int, error)
    GetBySlug(ctx context.Context, slug string) (*Project, error)
    Create(ctx context.Context, p *Project, skillIDs []string) error
    // ... modul lain mengikuti pola yang sama
}
```

5. Frontend & UI/UX Specification

5.1 Prinsip Desain

Modern Dark Mode Only. Tidak ada toggle tema. Tampilan bersih, kontras tinggi, monokrom. **Anti-Gradient Policy:** dilarang gradasi rainbow/multi-warna pada teks, header, dan tombol utama. Gunakan warna solid, border 1px halus, dan glassmorphism tipis. Satu-satunya efek "cahaya" yang diizinkan adalah glow tipis (box-shadow blur rendah, opasitas ≤ 25%) saat hover.

5.2 Design Tokens (taruh di `index.css` sebagai CSS variables, petakan ke `tailwind.config`)

Token	Nilai	Pemakaian
`--bg`	`#09090b`	Background halaman

Token	Nilai	Pemakaian
`--surface`	`#121214`	Card, section alternatif
`--surface-2`	`#18181b`	Input, hover surface
`--border`	`#27272a` (zinc-800)	Border default 1px
`--border-strong`	`#3f3f46` (zinc-700)	Border hover/fokus
`--text`	`#fafafa`	Teks utama
`--text-muted`	`#a1a1aa`	Teks sekunder
`--text-faint`	`#71717a`	Meta, placeholder
`--accent`	`#fafafa` (putih)	Tombol primer solid, indikator aktif
`--accent-fg`	`#09090b`	Teks di atas tombol primer
`--danger` / `--success`	`#ef4444` / `#22c55e`	Status saja, bukan dekorasi

Glass: `background: rgba(18,18,20,.6); backdrop-filter: blur(12px); border: 1px solid rgba(255,255,255,.06)`. Radius: `8px` input/tombol, `12px` card, `16px` modal. Kontras teks minimal WCAG AA.

5.3 Tipografi

- Sans: **Inter** atau **Plus Jakarta Sans** (pilih satu, self-host via `@fontsource` agar tidak bergantung CDN).
- Mono: **JetBrains Mono** untuk badge tech stack, snippet kode, label teknis, dan tanggal meta.
- Skala: `display 48/56 (mobile 36/44)`, `h2 32/40`, `h3 20/28`, `body 16/26`, `small 14/20`, `mono-xs 12/16`. Bobot: 400, 500, 600 saja. `letter-spacing: -0.02em` untuk heading besar.

5.4 Komponen (shadcn/ui + Tailwind)

Install: `button, card, badge, input, textarea, select, dialog, sheet, tabs, table, dropdown-menu, toast (sonner), skeleton, form, tooltip, alert-dialog`. Semua di-theme ke token di atas (tanpa warna bawaan biru/ungu). Komponen kustom: `ProjectCard`, `SkillBadge`, `Timeline`, `CertificateViewerModal`, `MagneticButton`, `SectionHeading`, `MarkdownEditor` (admin), `FileDropzone` (admin).

5.5 Spesifikasi Animasi & Hover State

Elemen	Spesifikasi
ProjectCard	`transition-all duration-300 ease-out`; hover: thumbnail `scale-105` (container `overflow-hidden`), border berubah ke `--border-strong` + `box-shadow: 0 0 0 1px rgba(255,255,255,.12), 0 8px 32px rgba(255,255,255,.04)`; kartu naik `-translate-y-1`. Judul memanah ikon panah kecil yang bergeser 2px.
SkillBadge	Default: border `--border`, teks `--text-muted`, font mono. Hover: border + teks + glow tipis memakai `brand_color` skill lewat CSS variable `--badge-color` (`box-shadow: 0 0 12px color-mix(in srgb, var(--badge-color) 35%, transparent)`). Fokus keyboard memakai efek sama. Bila `brand_color` null, fallback putih.
Tombol primer	Solid putih, teks gelap. Hover: *fill-up animation* — pseudo-element `::before` naik dari bawah (`translateY(100%) → 0`, 250ms) mengisi warna `--surface-2` dan teks berganti terang. Tombol sekunder: outline 1px, hover fill.
MagneticButton	Hanya untuk CTA hero (maks 2 tombol). Elemen mengikuti kursor dalam radius 60px dengan pergeseran maks 8px (`framer-motion` `useSpring`, stiffness 200, damping 20), kembali ke posisi awal saat mouse keluar. **Nonaktif** pada layar sentuh dan saat `prefers-reduced-motion`.
Link teks	Underline animasi: garis 1px `scaleX(0→1)` dari kiri, 200ms.
Navbar	Sticky, glass. Indikator aktif: garis 2px di bawah item, dipindah dengan `layoutId` (framer-motion) berdasarkan section yang terlihat (`IntersectionObserver`, threshold 0.5).
Scroll	`scroll-behavior: smooth` + `scroll-margin-top` setara tinggi navbar; reveal section `opacity 0→1, translateY 16px→0`, 500ms, sekali saja (`once: true`).

Elemen	Spesifikasi
Cursor/Clickable	Semua elemen interaktif `cursor-pointer`, fokus `ring-2 ring-white/40 ring-offset-2 ring-offset-[#09090b]`; elemen non-clickable tidak boleh punya efek hover.
Reduced motion	Wajib: `@media (prefers-reduced-motion: reduce)` mematikan transform, magnetic, dan reveal.

Performa: animasi hanya `transform` dan `opacity`; gambar `loading="lazy"` + `width/height` eksplisit (hindari CLS); target Lighthouse Performance ⩾ 90, Accessibility ⩾ 95.

5.6 Halaman Publik (route `/`)

Satu halaman scroll dengan section ber-anchor, ditambah halaman detail.

1. **Navbar**: logo/nama, tautan Projects, Tech Stack, Experience, Certificates, Blog, Contact; tombol Resume (unduh `resume_path`).
2. **Hero**: nama, `headline`, bio singkat, badge "Open to work" bila aktif, CTA (View Projects, Contact), ikon sosial. Tanpa gradient text; latar bisa pola grid titik halus monokrom.
3. **Project Showcase** (`/` section + `/projects/:slug`): grid 3 kolom desktop / 2 tablet / 1 mobile; **Tech Stack Filter** berupa deretan `SkillBadge` yang bisa dipilih (multi-select, sinkron ke query `?skill=`), plus filter kategori. Detail proyek: thumbnail besar, `description_html`, daftar skill, tombol Repo/Demo, navigasi proyek sebelumnya/berikutnya.
4. **Tech Stack**: skill dikelompokkan per `group_name`, badge mono dengan ikon.
5. **Experience**: timeline vertikal (garis 1px, titik penanda), urut terbaru; filter tab (Work/Education/Organization).
6. **Certificates**: grid kartu dengan thumbnail; klik membuka **CertificateViewerModal**: gambar ditampilkan `object-contain`, PDF lewat `<iframe>` / `<object>` same-origin; ada tombol unduh, tutup (Esc), dan fokus terkunci di modal (a11y).
7. **Blog** (`/blog`, `/blog/:slug`): daftar kartu (cover, judul, excerpt, tanggal, waktu baca), detail memakai `content_html` dengan styling `prose` kustom dan blok kode mono. Render lewat DOMPurify sebagai lapisan kedua.
8. **Contact**: form (name, email, subject, message) dengan validasi zod yang mencerminkan aturan backend, honeypot tersembunyi, status loading/sukses/error via toast, serta tampilan pesan saat kena rate limit (429).

9. **Footer** dan halaman `404`.

Setiap halaman memasang `<title>`, meta description, dan Open Graph via `react-helmet-async`. State loading memakai Skeleton, state kosong memakai pesan ramah.

5.7 Halaman Admin CMS (`/admin`)

Layout: sidebar tetap (collapsible di mobile via Sheet) + topbar; tema sama (dark), tanpa animasi berlebihan. Route guard memanggil `/auth/me`; 401 → redirect `/admin/login`. Semua mutasi mengirim `X-CSRF-Token`; gunakan optimistic update hanya untuk toggle sederhana.

- **Login** (`/admin/login`): email + password, pesan error generik, tampilkan info saat terkunci/429.
- **Dashboard**: kartu statistik (proyek, skill, sertifikat, post, pesan unread dari `/admin/stats`), daftar 5 pesan terbaru, tautan cepat "Tambah Proyek".
- **Projects**: tabel (judul, kategori, status, featured, tanggal) dengan pencarian dan filter status; form create/edit: judul, slug otomatis, ringkasan, editor Markdown dengan preview sanitasi, upload thumbnail (dropzone + preview), pilih skill (multi-select), URL repo/demo, status, toggle featured.
- **Skills**: tabel + dialog form (nama, group, ikon, **color picker `brand_color`**, level, visibilitas, urutan).
- **Certificates**: tabel + form (judul, penerbit, ID, URL kredensial, tanggal terbit/kedaluwarsa, upload file gambar/PDF, thumbnail opsional, visibilitas).
- **Inbox Messages**: daftar dua panel (list + detail), filter status, tombol tandai dibaca/arsipkan/spam/hapus, tombol "Balas via email" (`mailto:`), badge jumlah unread di sidebar.
- **Modul tambahan**: Profile, Experiences, Categories, Posts (struktur CRUD sama; dikerjakan setelah modul utama).
- Semua penghapusan memakai `AlertDialog` konfirmasi; formulir mencegah submit ganda dan menampilkan error per-field dari respons `fields`.

6. Security Requirement Checklist

Antigravity wajib memenuhi seluruh butir dan menyertakan bukti (test atau catatan) di PR/commit terkait. Format: `[ ]` belum, `[x]` selesai.

6.1 Backend

- [ ] Password di-hash argon2id/bcrypt (cost ≥ 12); tidak pernah dilog atau dikembalikan di respons.

- [ ] JWT HS256, verifikasi algoritma eksplisit, `exp` wajib; secret ≥ 32 byte dari `.env`.
- [ ] Cookie sesi `HttpOnly`, `SameSite=Strict`, `Secure` di produksi.
- [ ] CSRF double-submit untuk seluruh mutasi `/admin/*`.
- [ ] Brute-force: rate limit login + kunci akun sementara; pesan error generik.
- [ ] Semua query parameterized (pgx); tidak ada string-concat SQL; linter `gosec` bersih.
- [ ] Validasi tiap payload dengan `validator`; `BodyParser` strict, tolak field tak dikenal, batas ukuran body.
- [ ] Markdown → HTML lewat goldmark (raw HTML dimatikan) → bluemonday; `content_html` tidak pernah diisi langsung dari input klien.
- [ ] Validasi URL: hanya `https://` untuk repo/demo/credential/sosial.
- [ ] Rate limit `/contact` + honeypot + batas panjang; IP disimpan sebagai hash berasam.
- [ ] CORS whitelist eksplisit, tanpa `*` bersama credentials.
- [ ] Security headers terpasang (CSP, nosniff, frame-ancestors, Referrer-Policy, Permissions-Policy, HSTS di produksi).
- [ ] Error handler global: 500 generik ke klien, detail hanya di log; tidak ada stack trace di respons.
- [ ] Log tidak memuat password, token, cookie, atau isi pesan; gunakan request ID.
- [ ] Otorisasi: seluruh route `/admin/*` di balik middleware Auth (uji dengan test tanpa cookie → 401).
- [ ] Timeout server (read/write/idle) dan batas koneksi DB pool diset.
- [ ] `govulncheck` dan `go mod verify` lolos; dependensi dipin.

6.2 Frontend

- [ ] Tidak ada `dangerouslySetInnerHTML` kecuali untuk `*_html` yang sudah melewati DOMPurify.
- [ ] Tidak ada secret/token di bundle atau `localStorage`; sesi hanya lewat cookie httpOnly.
- [ ] Link eksternal memakai `rel="noopener noreferrer"`.
- [ ] Validasi zod di form (UX), dengan asumsi server tetap sumber kebenaran.
- [ ] Variabel `VITE_*` hanya berisi data publik (mis. `VITE_API_BASE`).
- [ ] `npm audit` tanpa kerentanan high/critical; lockfile di-commit.
- [ ] Source map dinonaktifkan di build produksi.

6.3 Storage & Upload

- [ ] Whitelist ekstensi + verifikasi magic bytes; MIME dari klien tidak dipercaya.

- [ ] Ukuran maks 2 MB ditegakkan di server (bukan hanya klien).
- [ ] Nama file di-generate UUID; nama asli dibuang; tidak ada path dari input pengguna.
- [ ] Cek anti path-traversal (`filepath.Rel` , tolak `..` , null byte, symlink).
- [ ] Direktori upload tidak dapat mengeksekusi apa pun; respons file memakai `nosniff` .
- [ ] Hapus file lama saat record dihapus atau file diganti (tanpa file yatim).
- [ ] `./storage/uploads` dan `.env` ada di `.gitignore` .

6.4 Database

- [ ] User DB aplikasi berhak minimal (tanpa `SUPERUSER` / `CREATEDB`).
- [ ] Semua constraint `CHECK` / `FK` dari DDL diterapkan lewat migrasi.
- [ ] Seeder admin memaksa ganti password default; password seed tidak boleh dipakai di produksi.

7. Migration Roadmap to Appwrite Cloud

Dilakukan **setelah** seluruh fitur lokal stabil dan checklist Bagian 6 lolos. Prinsip: ganti implementasi di balik interface, bukan logika bisnis.

7.1 Pra-syarat

- Seluruh akses data lewat interface `*Repository` dan `StorageProvider` (Bagian 4.8).
- Semua path file relatif; konfigurasi dibaca dari env.
- Verifikasi dokumentasi Appwrite terbaru sebelum mulai: engine database yang tersedia (skema tabel/kolom dan tipe data), batas ukuran, serta runtime Go untuk Functions. Sesuaikan langkah di bawah dengan kondisi terkini.

7.2 Langkah-langkah

1. **Inventaris & backup**: `pg_dump` penuh + arsip `./storage/uploads` ; catat versi migrasi terakhir.
2. **Buat project Appwrite**: API key dengan scope minimal (databases, storage, functions); simpan di secret manager/env, bukan di repo.
3. **Petakan skema**: buat database dan 10 koleksi/tabel mengikuti DDL Bagian 3 (UUID → document/row ID, `TIMESTAMPTZ` → datetime, `JSONB` → JSON/string, `CHECK` → enum/validasi atribut, FK → relasi atau referensi ID). Buat indeks setara dengan `idx_*` . Dokumentasikan kolom yang tidak punya padanan langsung dan pindahkan validasinya ke service.

4. **Buat bucket**: bucket terpisah atau prefix per `kind` (thumbnails, certificates, resume, avatars, covers); set ekstensi yang diizinkan, ukuran maks 2 MB, dan izin baca publik hanya untuk aset yang memang publik.
5. **Implementasi `AppwriteStorageProvider`** dan `STORAGE_DRIVER=appwrite`; `PublicURL()` mengembalikan URL view/preview bucket. Jalankan unit test kontrak yang sama dengan driver lokal.
6. **Implementasi repository Appwrite** per modul, satu per satu, dengan test kontrak yang sama dengan versi Postgres (run test suite terhadap kedua implementasi).
7. **Skrip migrasi data** (`cmd/migrate-to-appwrite`): baca dari Postgres → tulis ke Appwrite secara idempoten (upsert by ID), unggah file dari disk ke bucket sambil memetakan `path` lama → file ID baru; hasilkan laporan jumlah record/file. Jalankan dulu pada project staging.
8. **Auth**: pertahankan JWT + tabel `users` sendiri (paling sedikit perubahan), atau migrasi ke Appwrite Auth sebagai keputusan terpisah; jangan campur keduanya.
9. **Contact Form Handler sebagai Appwrite Function (Go)**: pindahkan `POST /contact` → Function dengan validasi, honeypot, dan rate limit sendiri (mis. berbasis hash IP yang disimpan di koleksi `messages`/koleksi throttle); API key hanya di environment Function.
10. **Hosting**: frontend ke Appwrite Sites atau static hosting lain; backend Go dideploy sebagai container/VM atau dipecah menjadi Functions. Atur `CORS_ALLOWED_ORIGINS`, `COOKIE_SECURE=true`, domain kustom + HTTPS, dan header keamanan di lapisan hosting.
11. **Verifikasi**: jalankan ulang seluruh checklist Bagian 6, uji end-to-end (login admin, CRUD, upload, form kontak, viewer sertifikat), bandingkan jumlah record/file sumber vs tujuan, cek Lighthouse.
12. **Cutover & rollback**: bekukan penulisan lokal, migrasi delta terakhir, ganti env ke produksi. Simpan dump Postgres dan folder uploads selama minimal 30 hari; rollback = kembalikan `STORAGE_DRIVER=local` dan implementasi repository Postgres.

7.3 Kriteria Selesai Migrasi

- Seluruh test kontrak lulus pada implementasi Appwrite.
- Tidak ada referensi ke `./storage/uploads` di runtime produksi.
- Tidak ada secret di repo; API key Appwrite memakai scope minimum.
- Dokumen `RUNBOOK.md` berisi cara deploy, rotasi secret, backup, dan rollback.